

Hardware CWE™ Special Interest Group (SIG)

Chair: Bob Heinemann (MITRE)

Co-Chair: “Manna” Parbati Kumar Manna (Intel)

MITRE Team: Steve Christey Coley, Alec Summers

MITRE

August 21, 2026



Agenda – to update

REMINDER: This meeting is being recorded.

1	RTL WG, HW View, and Other Updates	Bob H	10 min
2	HW Lifecycle Discussion	Bob H	45 min
3	Memory Weaknesses - deferred	Bob H	---



Housekeeping

- **Schedule:**
 - **Next Meeting Sep 18:**
 - **Meeting is now the third Friday each month**
 - **12:30 – 1:30 PM EST (16:30 – 17:30 UTC)**
 - **Microsoft Teams**
- **Contact: cwe@mitre.org**
- **Mailing List: hw-cwe-special-interest-group-sig-list@mitre.org**
- **Minutes from previous meetings available on our GitHub site:**
 - <https://github.com/CWE-CAPEC/hw-cwe-sig>



Announcements

- **CWE 5.0 planned for October time frame.**
- **CWE Content Development Repository (CDR) is now fully public.**
 - <https://github.com/CWE-CAPEC/CWE-Content-Development-Repository/>
- **HW View Flattening set for 5.0**
- **HW CWEs relationship updates (PeerOf and CanAlsoBe) for 5.0**



Preview of Flattened HW View - Partial

-  **C** General Circuit and Logic Design Concerns - (1199)
 -  **B** Failure to Disable Reserved Bits - (1209)
 -  **B** Incorrect Register Defaults or Module Parameters - (1221)
 -  **B** Race Condition for Write-Once Attributes - (1223)
 -  **B** Improper Restriction of Write-Once Bit Fields - (1224)
 -  **B** Improper Prevention of Lock Bit Modification - (1231)
 -  **B** Improper Lock Behavior After Power State Transition - (1232)
 -  **B** Security-Sensitive Hardware Controls with Missing Lock Bit Protection - (1233)
 -  **B** Hardware Internal or Debug Modes Allow Override of Locks - (1234)
 -  **B** Improper Finite State Machines (FSMs) in Hardware Logic - (1245)
 -  **B** Improper Preservation of Consistency Between Independent Representations of Shared State - (1250)
 -  **B** Incorrect Selection of Fuse Values - (1253)
 -  **B** Incorrect Comparison Logic Granularity - (1254)
 -  **B** Improper Handling of Single Event Upsets - (1261)
 -  **B** Hardware Logic Contains Race Conditions - (1298)
-  **C** Core and Compute Issues - (1201)
 -  **B** CPU Hardware Not Configured to Support Exclusivity of Write and Execute Operations - (1252)
 -  **B** Sequence of Processor Instructions Leads to Unexpected Behavior - (1281)
 -  **B** Information Exposure through Microarchitectural State after Transient Execution - (1342)
 -  **B** Exposure of Sensitive Information during Transient Execution - (1420)
 -  **B** Exposure of Sensitive Information in Shared Microarchitectural Structures during Transient Execution - (1421)
 -  **B** Exposure of Sensitive Information caused by Incorrect Data Forwarding during Transient Execution - (1422)
 -  **B** Exposure of Sensitive Information caused by Shared Microarchitectural Predictor State that Influences Transient Execution



RTL Updates

*Received updates for many sections; incorporating for review at next meeting, 8/24

- **Entry Name**
- **Summary**
- **Extended Description**
- **Modes of Introduction**
- **Applicable Platforms**
- **Common Consequences**
- **Demonstrative Examples**
 - 3 Example drafts out for comment
 - VHDL and Verilog
- **Observed Examples**
 - Have CVE entries, but not public yet
 - We can point to the source directly
- **Detection Methods**
- **Potential Mitigations**
- **Related Weaknesses**
- **References**
 - Draft created and under review

Green: Mature draft text

Yellow: Early draft text still under review,

Red: still to be developed.



Meeting Expectations: CWE Phases for Hardware

Purpose: Discuss whether the current CWE phase values adequately represent hardware lifecycle concerns.

Desired outcome:

Decide whether CWE needs additional HW-relevant phase terms. The answer may be:

- No changes needed
- One additional phase
- Multiple additional phases
- Better guidance instead of new phases

Discussion focus:

- Are current phases specific enough to describe where HW weaknesses are introduced and mitigated.

Why precision matters: More precise phases could help CWE users:

- Better understand HW weakness root causes
- Identify where prevention or mitigation should occur
- Improve mapping and analysis consistency
- Support clearer HW guidance for designers, integrators, assessors, and tool vendors



Discussion Roadmap

1. CWE Product Lifecycle Concept
2. Modes of Introduction and Potential Mitigations Phase Examples
3. Current Lifecycle Vocabulary
4. What phases HW CWE is using today
5. Phase Themes for HW CWE
6. Bucketing HW Concerns in Current CWE Phases
7. Discussion



CWE Product Lifecycle Concept

- Schema provides a vocabulary that lists different phases in a product life cycle.
- Lifecycle is metadata, not a process model.
- The phase labels are independent of each other. Meaning that there is no ordering of phases. This is not something CWE captures or needs to capture.
- It tags weakness content with lifecycle phase labels for introduction and mitigation context.
- Lifecycle appears as Phase in both the Modes of Introduction and Potential Mitigations elements.

Modes of Introduction
Phase

*Where in the product lifecycle
a weakness can be
introduced.*

Potential Mitigations
Phase

*Where in the product lifecycle
the mitigation activity can be
applied.*



Modes of Introduction and Potential Mitigations

Phase Example (1 of 2)

CWE-1277: Firmware Not Updateable

Weakness ID: 1277

Vulnerability Mapping: ALLOWED

Abstraction: Base

▼ Potential Mitigations

Phase(s)	Mitigation
Requirements	Specify requirements to include the ability to update the firmware. Include integrity checks and authentication to ensure that untrusted firmware cannot be installed.
Architecture and Design	Design the device to allow for updating the firmware. Ensure that the design specifies how to distribute the updates and ensure their integrity and authentication.
Implementation	Implement the necessary functionality to allow the firmware to be updated.

▼ Modes Of Introduction

Phase	Note
Requirements	Requirements development might not consider the importance of updates over the lifetime of the product, or might not choose the ability due to concerns such as expense or speed to market.
Architecture and Design	Lack of planning during architecture development and design, or external pressures such as speed to market, could ignore the capability to update.
Implementation	The weakness can appear through oversight during implementation.



Modes of Introduction and Potential Mitigations

Phase Example (2 of 2)

CWE-1384: Improper Handling of Physical or Environmental Conditions

Weakness ID: 1384

Vulnerability Mapping: ALLOWED (with careful review of mapping notes)

Abstraction: Class

▼ Potential Mitigations

Phase(s)	Mitigation
Requirements	In requirements, be specific about expectations for how the product will perform when it exceeds physical and environmental boundary conditions, e.g., by shutting down.
Architecture and Design; Implementation	Where possible, include independent components that can detect excess environmental conditions and have the capability to shut down the product.
Architecture and Design; Implementation	Where possible, use shielding or other materials that can increase the adversary's workload and reduce the likelihood of being able to successfully trigger a security-related failure.

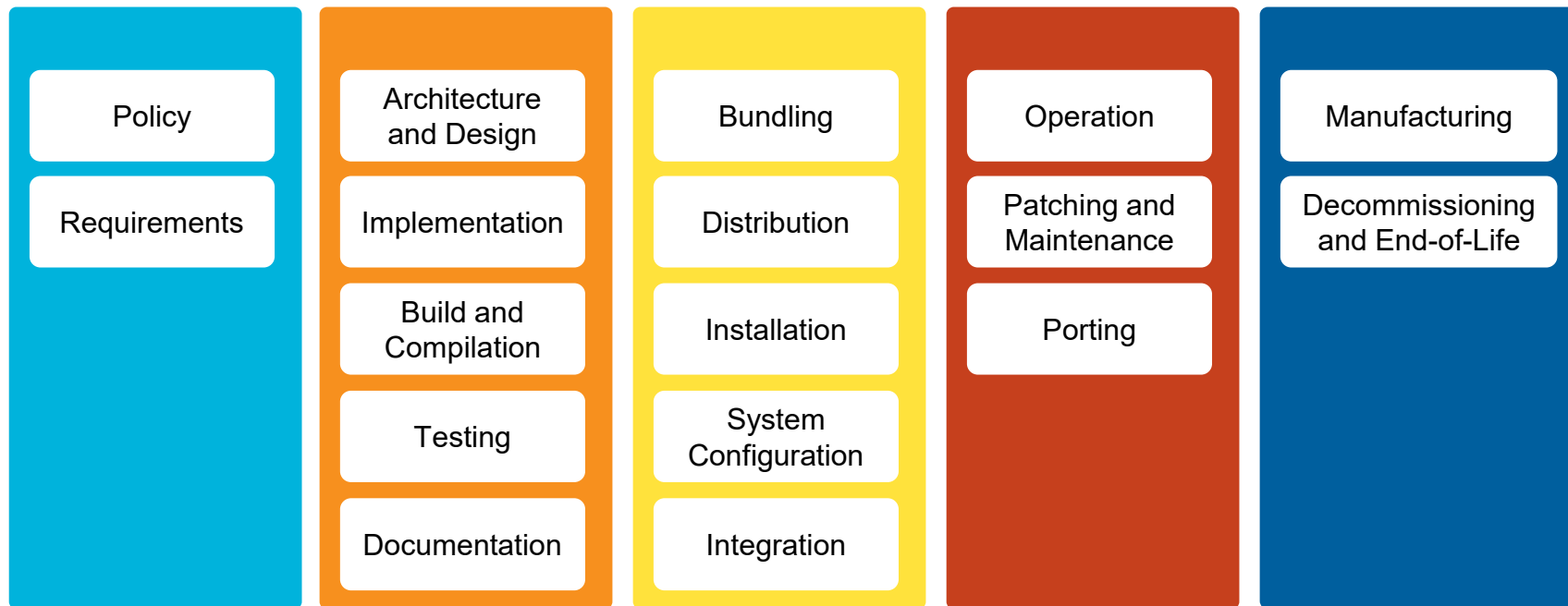
▼ Modes Of Introduction

Phase	Note
Architecture and Design	The product's design might not consider checking and handling extreme conditions.
Manufacturing	For hardware manufacturing, sub-par components might be chosen that are not able to handle the expected environmental conditions.



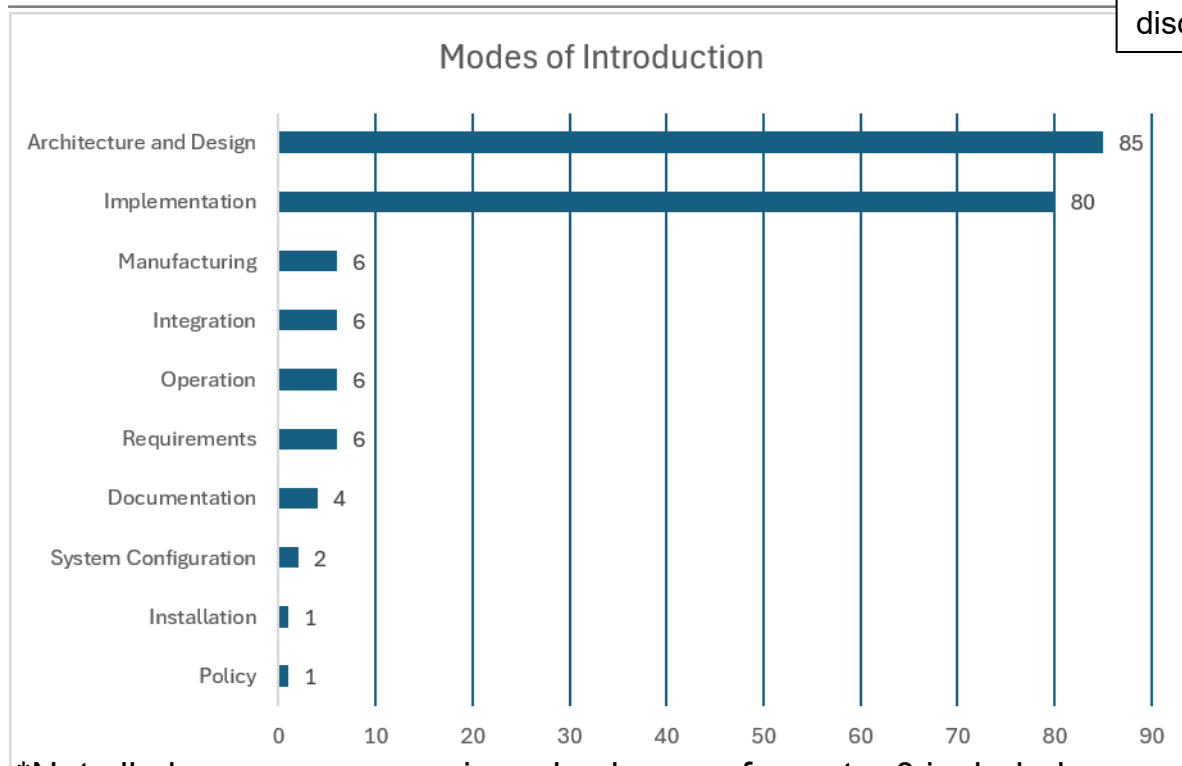
Current Lifecycle Vocabulary

Schema Version 7.2 (7.3 is latest public)



Where CWE indicates HW weaknesses are introduced today

AI Disclaimer: AI-generated bar chart values are preliminary and unverified; use as discussion inputs, not authoritative metrics.



HW weakness introduction is concentrated in two phases.

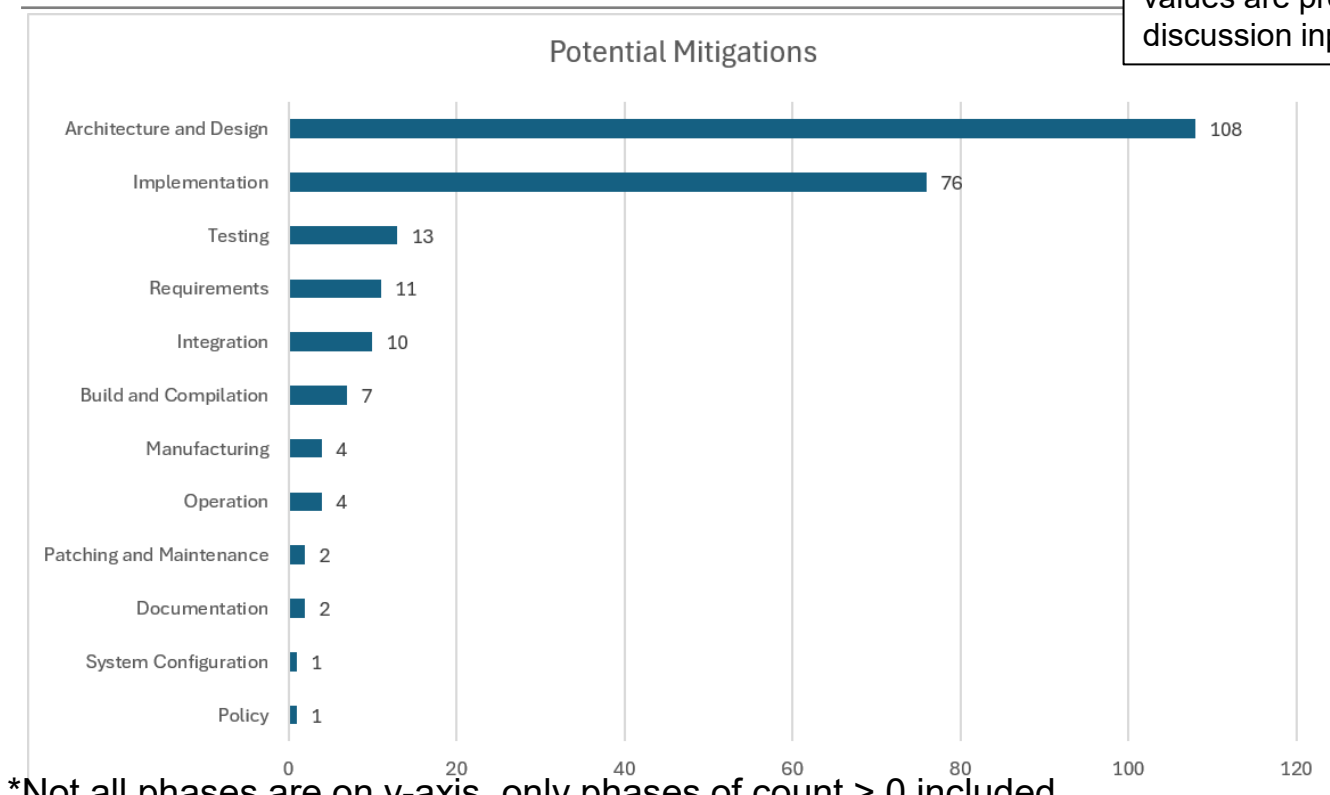
Are there specific hardware lifecycle activities that could be concentrated in these two phase labels?

*Not all phases are on y-axis, only phases of count > 0 included.



Where CWE indicates HW mitigations are placed today

AI Disclaimer: AI-generated bar chart values are preliminary and unverified; use as discussion inputs, not authoritative metrics.



HW weakness introduction is concentrated in two phases.

Are there specific hardware lifecycle activities that could be concentrated in these two phase labels?

*Not all phases are on y-axis, only phases of count > 0 included.



Phase Lifecycle Themes Emerging from Current HW CWE Content

The tables in the following slides summarize an AI-assisted review of current HW CWE content across:

- **Modes of Introduction**
 - Where HW weaknesses are currently described as being introduced.
- **Potential Mitigations**
 - Where HW weaknesses are currently described as being mitigated.

This analysis is intended:

- Review of HW CWE Modes of Introduction (MOI) and Potential Mitigations (PM)
- Themes show how current HW CWE content maps to existing lifecycle phases
- **These are discussion inputs, not proposed new lifecycle phases**

Goal: Understand what product lifecycle concepts are already represented so the HW SIG can decide what phases HW CWE should support.



HW CWE Phase Theme Landscape

Design Definition

- HW security requirements
- Architecture / microarchitecture / ISA / interface design
- Security-sensitive documentation

Design Realization

- RTL/HDL implementation
- IP / SoC / hardware-system integration
- Toolchain and HW/SW execution-boundary mitigations

Post-Design Assurance

- Verification / validation / testing / detection
- Policy, governance, certification, and assurance planning

Production Enablement

- Provisioning / personalization / lifecycle-state programming
- Manufacturing / fabrication / assembly / physical production
- Supply-chain / component selection / qualification

Fielded Product Lifecycle

- Updateability / patchability / post-release maintenance
- Field operation / rated environment / runtime configuration
- Decommissioning / end-of-life data disposition



Bucketing of HW Concerns in current CWE Phases

	CWE Phase “as is”	HW Themes
Pre-si	Requirements	HW security requirements, updateability, trust assumptions
	Architecture and Design	microarchitecture, ISA, register/interface design
	Implementation	RTL/HDL, lock logic, access-control logic
	Integration	IP blocks, SoC fabrics, parent/child connections
Post Si	Manufacturing	provisioning, fuse programming, silicon test
Pre-Si/Post-Si	Testing	verification/detection, not necessarily mitigation



Discussion

What hardware lifecycle vocabulary should we include in the CWE schema?

Keep in mind that terms should:

- Be recognizable across the HW community..
- Not be overly detailed or tied to one company, product type, or development methodology.
- Not require CWE to adopt a full product-development lifecycle.
- Cover the recurring lifecycle themes surfaced by current HW CWE content.
- Be just specific enough to distinguish the HW activities that matter for weakness introduction and mitigation.



Next Meeting (Sep 18)

CWE@MITRE.ORG

- **Mailing List:** hw-cwe-special-interest-group-sig-list@mitre.org
 - **NOTE:** All mailing list items are archived publicly at:
 - <https://www.mail-archive.com/hw-cwe-special-interest-group-sig-list@mitre.org/>
- **What would members of this body like to see for the next HW SIG agenda?**
- **Questions, Requests to present? Please let us know.**



Schema Terms Suggested by Steve

- - **Product requirements documentation (PRD)**
- - **Engineering validation and testing (EVT)**
- - **Design validation and testing (DVT)**
- - **Production validation and testing (PVT)**
- - **Mass production (MP)**
- - **End-of-life (EOL)**

